

AUDIT RATE TECH

SMART CONTRACT SECURITY AUDIT

Auren Protocol (AU)
BNB Smart Chain

Final Report - Version 1.1
Assessment date 30 August 2026
Contract
0x6951822a267f4ce29af8eb0db46843f585aeb352

Manual Review • Static Analysis • Foundry PoCs
Fuzz / Property Testing • On-chain Verification

Assessment at a Glance

Plain-language summary for the client, token holders and other readers who do not need to review every technical finding.

Project	Auren Protocol (AU)
Network	BNB Smart Chain (BSC)
Contract	0x6951822a267f4ce29af8eb0db46843f585aeb352
Assessment status	Completed - audited with open findings
Findings	0 Critical • 0 High • 3 Medium • 3 Low • 1 Informational
Audited workspace commit	0fc6217e62f5c5bf51d5a81918a9255f4b003fe9

What was checked

- Solidity source and compilation with Solidity 0.8.14.
- ERC20 transfers, transferFrom allowances and balance accounting.
- Buy/sell fees and automatic fee conversion.
- PancakeSwap V2 interaction and AU/WBNB pair registration.
- Owner permissions: blacklist/whitelist, fees, max transaction limit, pair classification and asset recovery.
- Selected live BSC configuration and deployed runtime fingerprint.

What was executed

Security activity	Result
Targeted Foundry security tests	12 executed successfully
Fuzz testing	6 properties x 256 = 1,536 executions
Fee-math property testing	1,000 generated runs
Static analysis	Slither-assisted review + manual triage
On-chain verification	Selected configuration and runtime fingerprint verified

What was not covered

The assessment did not test the website/frontend, private-key custody, off-chain infrastructure, market or token-price performance, PancakeSwap internals, or future owner configuration changes. It was not a formal mathematical verification and did not execute live mainnet trades using real user funds.

Client conclusion

No Critical or High-severity vulnerability was identified in the reviewed scope. Three Medium and three Low implementation findings were reproduced. These remain Open because no patched source was supplied for a remediation review.

Overall: the security assessment is complete for the stated contract snapshot. The correct description is audited with open findings, not vulnerability-free or fully remediated.

Audit Dashboard

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	0	3	3	1

12 Targeted security tests	1,536 Fuzz executions	1,000 Fee-math property runs
-------------------------------	--------------------------	---------------------------------

OPEN FINDINGS

Final report status: assessment complete; findings remain open. This report does not certify that the contract requires no changes. Three Medium and three Low implementation findings were reproduced and are recommended for remediation.

No Critical or High-severity vulnerability was demonstrated in the reviewed scope. This is materially different from saying that the contract has no issues.

Assessment target

Contract	0x6951822a267f4ce29af8eb0db46843f585aeb352
Compiler	Solidity 0.8.14
Source SHA-256	83af443b151676d6978e04bd8c1a33b30309e0cc00a1b18882e19ae11e61e6dc
Runtime bytecode Keccak-256	0x4bde947ff3a34a33a696c4efc7f648305dcebe3c64883566ca227536eb93cb54
Git commit	0fc6217e62f5c5bf51d5a81918a9255f4b003fe9

1. Executive Summary

Audit Rate Tech assessed Auren Protocol token contract using manual source review, Slither-assisted static analysis, deterministic Foundry proof-of-concept testing, fuzz/property testing and selected on-chain verification.

The assessment produced seven reportable items: three Medium, three Low and one Informational. The most important implementation issues are the silent mutation of requested transfer amounts, the resulting transferFrom allowance mismatch, and the absence of a minimum-output bound during automatic fee conversion.

The audit is technically complete for the stated snapshot and scope. However, ART-01 through ART-06 remain Open; no remediation commit or patched deployment was supplied for verification.

Recommended release posture

The reviewed deployment can be described as audited with findings, not as vulnerability-free or fully remediated. A remediation review should be performed if the client changes the source in response to this report.

2. Engagement & Scope

In scope

- AurenProtocol.sol and included interfaces/libraries.
- ERC20 transfer and allowance behavior.
- Buy/sell fee logic and fee conversion.
- Owner-controlled configuration and privileged actions.
- PancakeSwap V2 router/pair interaction assumptions.
- Selected deployed state at the assessment snapshot.

Out of scope

- Website, frontend and user interfaces.
- Private-key custody, multisig operations and operational security.
- PancakeSwap implementation internals beyond interaction assumptions.
- Market performance, liquidity depth, token price and investment risk.
- Off-chain infrastructure and third-party services.
- Future owner parameter changes or source changes after the snapshot.

Immutable audit target

Network	BNB Smart Chain
Contract	0x6951822a267f4ce29af8eb0db46843f585aeb352
Reviewed source	src/AurenProtocol.sol
Solidity	0.8.14
Source SHA-256	83af443b151676d6978e04bd8c1a33b30309e0cc00a1b18882e19ae11e61e6dc
Runtime bytecode Keccak-256	0x4bde947ff3a34a33a696c4efc7f648305dcebe3c64883566ca227536eb93cb54
AU/WBNB pair	0x483b226f59e0A0C0e1458f8935F743CFBE88Bc17

3. Methodology & Timeline

Stage	Status
Source acquisition	Completed
Exact compiler build	Completed
Manual review	Completed
Static analysis	Completed
Targeted PoC testing	Completed
Fuzz/property testing	Completed
On-chain verification	Completed
Initial assessment	30 Aug 2026
Remediation review	Not performed

Methodology

Manual review

Business logic, transfer semantics, allowance accounting, fee distribution, privileged controls and external-call behavior.

Static analysis

Slither findings were manually triaged; scanner warnings were not automatically classified as vulnerabilities.

Targeted PoCs

Twelve Foundry tests exercised concrete security edge cases and privileged behaviors.

Fuzzing

Six properties were run for 256 cases each, for 1,536 generated executions.

Property testing

Fee arithmetic invariants were exercised for 1,000 generated cases.

On-chain checks

Owner, fund address, fees, max transaction amount, trade state, AMM pair registration and runtime fingerprint were recorded.

4. Architecture & Attack Surface

The primary trust and value-flow relationships reviewed are summarized below.

```
OWNER |-- fees / blacklist / whitelist / maxTx / pair classification | USER ----> AUREN TOKEN ----> PANCAKESWAP PAIR |  
| fee tokens v AUTOMATIC CONVERSION | v FUND ADDRESS
```

Security boundaries

- Users depend on ERC20 transfer semantics implemented by AUREN.
- AMM-related transfers depend on owner-controlled pair classification and trading activation.
- Fee conversion depends on the external router and current market execution conditions.
- Fund distribution depends on the configured fundAddress accepting native BNB.
- Owner authority materially changes the token's post-deployment behavior.

5. Findings Summary

ID	Severity	Status	Finding
ART-01	Medium	Open	Silent reduction of full-balance transfers
ART-02	Medium	Open	transferFrom() can consume more allowance than value transferred
ART-03	Medium	Open	Automatic fee swaps execute without a minimum output
ART-04	Low	Open	Fee receiver failure can revert sells when auto-swap triggers
ART-05	Low	Open	Previous fund addresses retain fee-whitelist privileges
ART-06	Low	Open	claimToken() does not validate ERC20 transfer success
ART-07	Informational	Acknowledged	Extensive privileged control over trading conditions

Status definitions: Open = reproduced and not yet verified as remediated. Acknowledged = documented trust/design property rather than a defect requiring a mandatory code fix.

MEDIUM

ART-01 - Silent Reduction of Full-Balance Transfers

Status	Open
Category	ERC20 / Business Logic
Affected component	AUREN._transfer()
Evidence test	testFullBalanceTransferIsSilentlyReduced(); testDustBalanceCannotBeTransferred(); fuzz: testFuzzFullBalanceTransferIsReduced()

For non-whitelisted endpoints, _transfer() silently caps the requested amount to 99.99% of the sender's balance when the request exceeds that cap.

Affected logic

```
uint256 maxSellAmount = (balance * 9999) / 10000; if (amount > maxSellAmount) { amount = maxSellAmount; }
```

Reproduction / scenario

1. A non-whitelisted holder owns a balance B. 2. The holder requests transfer(recipient, B). 3. The call succeeds. 4. The recipient receives less than B and a residual balance remains. The deterministic and fuzz tests reproduced this behavior.

Impact

A successful ERC20 transfer can move less than the caller requested. Small balances can become effectively non-transferable dust. Integrations that assume standard transfer semantics can account for the transaction incorrectly.

Recommendation

Do not mutate the requested amount. If full-balance transfers are intentionally forbidden, revert explicitly with a clear error.

MEDIUM

ART-02 - transferFrom() Can Consume More Allowance Than Value Transferred

Status	Open
Category	ERC20 / Accounting
Affected component	AUREN.transferFrom(), AUREN._transfer()
Evidence test	testTransferFromConsumesFullAllowanceButTransfersLess(); fuzz: testFuzzTransferFromAllowanceMismatch()

transferFrom() subtracts the original requested amount from allowance even when _transfer() internally reduces the amount actually delivered.

Affected logic

```
_transfer(sender, recipient, amount); if (_allowances[sender][msg.sender] != MAX) { _allowances[sender][msg.sender] =  
_allowances[sender][msg.sender].sub(amount); }
```

Reproduction / scenario

1. Owner approves spender for amount A. 2. Spender calls transferFrom(..., A). 3. _transfer() reduces the effective transfer. 4. Recipient receives less than A. 5. Allowance is nevertheless reduced by A.

Impact

Allowance consumption can exceed the value delivered to the recipient, producing inconsistent ERC20 accounting and unexpected integration behavior.

Recommendation

Remove silent transfer truncation. If amount adjustment remains, allowance accounting must use the actual transferred value.

MEDIUM

ART-03 - Automatic Fee Swaps Execute Without a Minimum Output

Status	Open
Category	DEX / MEV / Slippage
Affected component	AUREN.swapTokenForFund()
Evidence test	testInternalSwapUsesZeroMinimumOutput()

The internal token-to-BNB conversion passes zero as amountOutMin to the router.

Affected logic

```
_swapRouter.swapExactTokensForETHSupportingFeeOnTransferTokens( tokenAmount.sub(lpAmount), 0, path, address(this), block.timestamp );
```

Reproduction / scenario

When automatic fee conversion is triggered, the router is permitted to accept any positive output. The targeted mock-router test captured amountOutMin = 0.

Impact

Fee conversion can execute at a materially unfavorable price during volatile or manipulated market conditions and may be exposed to adverse MEV ordering.

Recommendation

Apply a bounded slippage policy using a defensible quote/oracle mechanism, or redesign conversion so execution is not forced without a minimum output.

LOW

ART-04 - Fee Receiver Failure Can Revert Sells When Auto-Swap Triggers

Status	Open
Category	Availability / External Call
Affected component	AUREN.swapTokenForFund()
Evidence test	testRevertingFundAddressCanBlockSellWhenSwapTriggers()

Fee proceeds are sent to fundAddress using transfer(). A receiver that rejects BNB causes the entire execution path to revert.

Affected logic

```
if (fundAmount > 0) payable(fundAddress).transfer(fundAmount);
```

Reproduction / scenario

A PoC configured a fund receiver that rejects BNB. Once automatic conversion attempted payout, the sell reverted.

Impact

A privileged misconfiguration or incompatible receiver can block sells when automatic fee conversion reaches the payout stage.

Recommendation

Validate the receiver and decouple payout from user transfer execution where practical. Consider a pull-payment model or deliberate failure handling.

LOW

ART-05 - Previous Fund Addresses Retain Fee-Whitelist Privileges

Status	Open
Category	Access Control / Configuration
Affected component	AUREN.setFundAddress()
Evidence test	testOldFundAddressRemainsWhitelisted(); testFundAddressCanBeSetToZero()

Changing fundAddress automatically whitelists the new receiver but does not revoke the previous receiver's fee exemption. address(0) is also accepted.

Affected logic

```
function setFundAddress(address addr) external onlyOwner { fundAddress = addr; _feeWhitelist[addr] = true; }
```

Reproduction / scenario

After fund rotation, the old address remains fee-whitelisted. A separate test confirmed that the zero address can be assigned.

Impact

Historical fund wallets can accumulate privileged fee-exempt status, while a zero fund address can create an invalid payout configuration.

Recommendation

Reject address(0) and revoke the old fund address exemption unless continued privilege is explicitly intended.

LOW

ART-06 - claimToken() Does Not Validate ERC20 Transfer Success

Status	Open
Category	ERC20 / Asset Recovery
Affected component	AUREN.claimToken()
Evidence test	testClaimTokenDoesNotRevertWhenTransferReturnsFalse()

The owner recovery function ignores the boolean returned by `IERC20.transfer()`.

Affected logic

```
function claimToken(address token, uint256 amount, address to) external onlyOwner { IERC20(token).transfer(to, amount); }
```

Reproduction / scenario

A mock ERC20 returned false from `transfer()`. `claimToken()` nevertheless completed without reverting.

Impact

Operational tooling can observe a successful transaction even though the requested token recovery did not occur.

Recommendation

Use `SafeERC20.safeTransfer()` or otherwise validate successful transfer behavior.

INFORMATIONAL

ART-07 - Extensive Privileged Control Over Trading Conditions

Status	Acknowledged
Category	Trust Model / Centralization
Affected component	Owner-only administrative functions
Evidence test	testOwnerCanFreezeHolderUsingBlacklist(); testOwnerCanClassifyArbitraryAddressAsSwapPair(); testOwnerCanSetFeesNearTwentyFivePercent(); testOwnerCanSetMaxTxToZeroAndBlockBuy()

The owner can materially alter trading behavior through blacklisting, fee exemptions, fee levels, max transaction amount, swap-pair classification, fund receiver selection, trading activation and asset recovery.

Affected logic

```
setBlackList(...) / setFeeWhiteList(...) setFees(...) / setMaxTxAmount(...) setSwapPairList(...) /  
setFundAddress(...) startTrade(...) / claimBalance(...) / claimToken(...)
```

Reproduction / scenario

Tests confirmed holder freezing, arbitrary pair classification, 24.99% buy/sell fee configuration and maxTXAmount = 0.

Impact

This is an intentional trust assumption rather than an external exploit. Users must trust the owner not to use these controls adversely.

Recommendation

Document the trust model prominently. Consider multisig/timelock governance, tighter bounds and removal of powers that are not operationally required.

6. On-chain Snapshot

Parameter	Observed value
Owner	0xF918D4e107dE957bb890E420f523B862c5c01Df1
Fund address	0xF918D4e107dE957bb890E420f523B862c5c01Df1
Buy fund fee	300 bps (3.00%)
Sell fund fee	800 bps (8.00%)
Buy / sell LP fee	0 / 0 bps
maxTXAmount	1e27 base units
totalSupply	1e27 base units
startTradeBlock	0
AU/WBNB pair registered	true

These values are a point-in-time snapshot. Owner-controlled values may change after publication.

7. Static Analysis Triage

Slither was used as a supporting detector. Potential reentrancy warnings around router interactions were reviewed but were not promoted to a reportable vulnerability because an exploitable path was not demonstrated in the reviewed configuration and tests.

Non-reportable scanner observations included naming/style warnings, immutable/constant suggestions, single-use internal functions/modifiers, default-initialized locals and complexity/code-quality observations without demonstrated security impact.

8. Remediation Status

Finding	Status	Priority
ART-01	Open	P1
ART-02	Open	P1
ART-03	Open	P2
ART-04	Open	P3
ART-05	Open	P3
ART-06	Open	P4
ART-07	Acknowledged	Trust model

A remediation review was not performed because no patched source or remediation commit was supplied. If fixes are made, Audit Rate Tech should verify the new commit and rerun the relevant regression tests before marking findings Resolved.

Appendix A - Verification Record

Artifact	Value
Source SHA-256	83af443b151676d6978e04bd8c1a33b30309e0cc00a1b18882e19ae11e61e6dc
Runtime bytecode Keccak-256	0x4bde947ff3a34a33a696c4efc7f648305dcebe3c64883566ca227536eb93cb54
AU/WBNB pair	0x483b226f59e0A0C0e1458f8935F743CFBE88Bc17
Targeted security tests	12 / 12 executed successfully
Fuzz executions	6 properties x 256 = 1,536
Fee-math property runs	1,000
Git commit	0fc6217e62f5c5bf51d5a81918a9255f4b003fe9

Interpretation of PASS

A passing security test means the expected test condition was reproduced. For vulnerability PoCs, PASS can mean that the vulnerable behavior was successfully demonstrated; it does not mean the contract is free of that issue.

Appendix B - Disclaimer

This report is a point-in-time security assessment of the reviewed smart-contract source and selected deployed state. A security audit cannot guarantee the absence of all defects, economic attacks, operational failures, private-key compromise, third-party failures or future vulnerabilities.

The assessment does not constitute financial, investment, legal or regulatory advice. Changes to source code, deployment configuration, privileged roles, liquidity conditions, external dependencies or owner-controlled parameters may invalidate parts of this report.

The term 'Final Report' means the assessment document is finalized for the reviewed snapshot. It does not mean all findings are resolved. Finding status is stated individually in this report.

Audit Rate Tech

Smart Contract Security Assessment

Auren Protocol (AU)

Final Report v1.1 - 30 August 2026